# Insecure by Design: A Hands-On Learning Platform for Web Security Training

Progress Report 2

CSIS 4495-003 | Applied Research Project

Winter 2026

Instructor: Arasanipalai Kandhadai, Padmapriya

Thilan Udahage Don | 300398798

# Work Logs (Feb 22 – Mar 2)

Thilan Udahage Don

| Date | Number of Hours | Description of Work |
|---|---|---|
| Feb 22 | 1 | Reviewed the current progress of the SQL Injection and XSS modules and planned the next steps for the upcoming implementation phase. Outlined the remaining tasks for the original design approach. |
| Feb 23 | 2 | Began initial work on the Stored XSS module as planned. Set up the basic page structure, reviewed sanitization approaches, and drafted the initial UI layout for user input and output rendering. |
| Feb 24 | 1.5 | Began redesigning the SQL Injection module based on instructor feedback. Planned a three-level challenge structure (OR injection, numeric injection, blind boolean SQLi) and drafted the new UI layout using Bootstrap accordion. |
| Feb 25 | 2 | Removed old SQL Injection demo logic and UI. Implemented the new SqlInjectionController with AJAX endpoints for level validation. Started integrating progress tracking logic into the backend. |
| Feb 27 | 2.5 | Implemented SqlInjectionChallengeService with payload validation logic for each level. Added pattern matching for OR, numeric, and boolean SQLi. |
| Feb 28 | 2 | Added Thymeleaf conditions to lock/unlock levels and experimented with different approaches for hiding Level 2 and Level 3 until prerequisites are completed. Implemented partial UI logic but still working on fully hiding the next challenges. Merged the UI behavior refinements originally planned for Mar 1 into this session. |
| Feb 29 | 1 | Fixed routing issue causing 404 errors (/sql-injection vs /sql-injection/sqli). Ensured correct template resolution and verified controller mappings. |
| Mar 2 | 1 | Completed end-to-end testing of the challenge flow. Verified progress persistence, UI behavior, unlock logic, and feedback messages. Completed the |

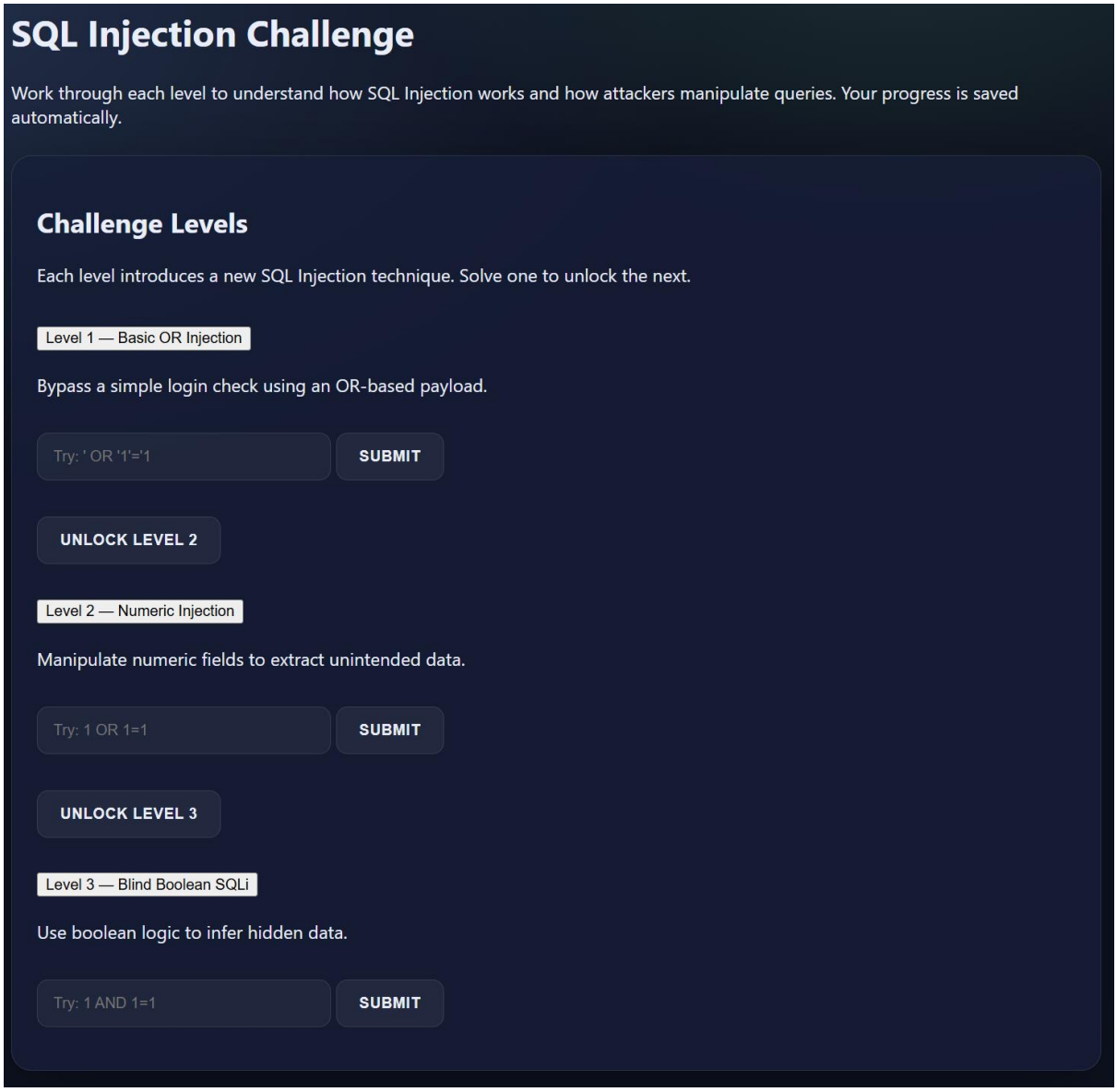
| Date | Number of Hours | Description of Work |
|---|---|---|
| | | Progress Report 2 documentation and cleaned up code formatting. |

## Summary Description

During this reporting period, I shifted from the original plan of continuing the Stored XSS module to implementing a fully redesigned, challenge-based SQL Injection learning experience. This pivot was based on feedback received during the Feb 24 meeting with our instructor, where we were encouraged to make the platform more interactive and engaging. Following that direction, I removed the old demo-style SQL Injection implementation and replaced it with a progressive, three-level challenge architecture. I designed a new UI using Bootstrap accordion components, implemented AJAX-based level validation, and created a backend structure that includes a dedicated controller, service, and persistent progress tracking through the  entity.

One challenge I encountered was ensuring that Levels 2 and 3 remain completely hidden until the previous level is completed. I successfully implemented the unlock-button logic, level-completion tracking, and UI disabling, but I am still working on the final step of fully hiding the next challenge sections until prerequisites are met. This will be refined after receiving instructor feedback on the new architecture.

Overall, the redesign creates a more structured, hands-on learning flow that encourages experimentation and reinforces understanding through incremental challenges. The new approach significantly improves user engagement and aligns the module with modern cybersecurity training practices.




## Repo Check-In of Implementation Completed

Since the midterm reporting period, I have completed substantial design and implementation work for the new challenge-based SQL Injection module. Because this redesign represents a major architectural shift from the original demo-based approach, I have prepared the updated implementation locally and will upload the full project as a ZIP, once I have the instructor's approval. These include:

- Removal of the old SQL Injection demo implementation, including the vulnerable/safe query service, DemoUser model, and associated SQL files.
- Addition of the new SqlInjectionController with AJAX endpoints for Level 1–3 challenge validation.
- Creation of the SqlInjectionController containing the logic for OR-based, numeric, and boolean SQL injection payload checks.
- Addition of the ChallengeProgress entity and repository to support persistent tracking of user progress across challenge levels.
- Full rewrite of the SQL Injection UI (sqli.html) using a Bootstrap accordion structure with locked/unlocked levels.
- Updated JavaScript for payload submission, feedback rendering, and manual unlock button behavior.
- Cleanup of routing, template paths, and folder structure under the Implementation directory to align with the new architecture.

## AI Use Section

**Table of AI Tools and Specific Use**

| AI Tool | Version | Feature Used | Value Add |
|---|---|---|---|
| Chatgpt | 5.1 free | Help with Maven dependencies | Used only to get an idea, then did my own research and continued. |

**Appendix**

## References